# Electronic Prescriptions for Controlled Substances (EPCS)

## EPCS overview

The US Drug Enforcement Administration (DEA) Electronic Prescriptions for Controlled Substances (EPCS) is a rule that went into effect on 1 June 2010. It revised DEA regulations for prescribers and pharmacies, allowing the e-prescribing of controlled substances. The regulation provides pharmacies, hospitals, and practitioners with the ability to use modern technology for controlled substance prescriptions while maintaining the closed system of controls on controlled substances. Prescribers can digitally sign, transmit, report, and archive electronic prescriptions, while pharmacies can receive, dispense, and archive these electronic prescriptions.

The regulation covers:

- Logical access controls for both prescribers and pharmacy systems
- Multi-factor authentication for prescribers and administrators of prescribers
- Digital signing of prescriptions for prescribers
- Record keeping for both prescribers and pharmacies
- Reporting and auditing of both prescribers and pharmacies
- Data backups and archiving for both prescribers and pharmacies

DEA uses the following definitions for multi-factor authentication (MFA):

- Two-factor credentials
  - Something you know – a knowledge factor
  - Something you have – a hard token stored separately from the computer being accessed
  - Something you are – biometric information
- Hard token
  - A cryptographic key stored on or a one-time password (OTP) transmitted to a specialized hardware device (for example, a PDA, mobile phone, smart card, USB key) rather than a general-purpose computer.

For more information, see Title 21 Code of Federal Regulations Part 1311.115 *Additional requirements for two-factor authentication*.

## EPCS multi-factor authentication requirements

In EPCS, the DEA provides several requirements related to MFA for administrators of prescribing systems, prescribers, and digital signing.

- Two-factor authentication must be used to assign a prescriber within the electronic system, approve a prescription entry, and digitally sign a prescription.
- Two of the factors must be of the following three options: a username/password, a hard token, or a biometric identification. The DEA has stated that the use of a type of token or OTP generator must meet the same requirements as defined for a hard token under the current regulation.
- If a hard token is used, it must meet FIPS 140 Security Level 1 for cryptographic devices or OTP devices.
- The hard token must be stored on a device that is separate from the computer being used to access the application.

## EPCS token requirements and FIPS 140

The Federal Information Processing Standard (FIPS) 140 is a US government standard that defines minimum security requirements for cryptographic modules in information technology products and systems. Testing against the FIPS 140 standard is maintained by the Cryptographic Module Validation Program (CMVP), a joint effort between the US National Institute of Standards and Technology (NIST) and the Canadian Centre for Cyber Security, a branch of the Communications Security Establishment (CSE) of Canada. For more information, see Azure FIPS 140 documentation.

EPCS requires that solutions for **hard tokens** use cryptographic modules validated at FIPS 140 Level 1 to ensure end users receive a high degree of security, assurance, and non-repudiation. For more information, see Title 21 Code of Federal Regulations Part 1311.115 *Additional requirements for two-factor authentication*. The types of hard tokens commonly used have either a cryptographic module as part of the token itself or a random number generator, also called an OTP generator.

# Azure and EPCS multi-factor authentication

As mentioned previously, two of the factors for EPCS multi-factor authentication must be of the following three options:

1. Username/password
2. Hard token
3. Biometric identification

This section focuses on Azure support for **hard tokens** to meet EPCS multi-factor requirements. There are several requirements specific to biometrics, as described in Title 21 Code of Federal Regulations Part 1311.116 *Additional requirements for biometrics*. However, these requirements aren't applicable to Azure.

The Microsoft Authenticator app provides an extra level of security to your Azure AD account. It's available on mobile phones running Android and iOS. With the Microsoft Authenticator app, you can provide secondary verification for MFA scenarios to meet your EPCS MFA requirements. As mentioned previously, EPCS requires that solutions for hard tokens use cryptographic modules validated at FIPS 140 Level 1 to ensure end users receive a high degree of security, assurance, and non-repudiation. The Microsoft Authenticator app meets FIPS 140 Level 1 validation requirements for all Azure AD authentications, as explained in Authentication methods in Azure Active Directory - Microsoft Authenticator app. FIPS 140 compliance for Microsoft Authenticator is currently in place for iOS and in progress for Android.

Moreover, Azure can help you meet and **exceed** your EPCS MFA requirements by supporting the highest Authenticator Assurance Level 3 (AAL3), as described in the National Institute of Standards and Technology (NIST) SP 800-63 *Digital Identity Guidelines*. According to NIST SP 800-63B Section 4.3 , multi-factor **authenticators** used at AAL3 shall rely on hardware cryptographic modules validated at FIPS 140 Level 2 overall with at least FIPS 140 Level 3 for physical security, which exceeds the EPCS MFA requirements. **Verifiers** at AAL3 shall be validated at FIPS 140 Level 1 or higher.

Azure Active Directory (Azure AD) supports both authenticator and verifier NIST SP 800-63B AAL3 requirements:

- **Authenticator requirements:** FIDO2 security keys, smartcards, and Windows Hello for Business can help you meet AAL3 requirements, including the underlying FIPS 140 validation requirements. Azure AD support for NIST SP 800-63B AAL3 **exceeds** the EPCS multi-factor authentication requirements.
- **Verifier requirements:** Azure AD uses the Windows FIPS 140 Level 1 overall validated cryptographic module for all its authentication related cryptographic operations. It is therefore a FIPS 140 compliant verifier.

For more information, see Azure NIST SP 800-63 documentation.

# Applicability

- Azure
- Azure Government

# Guidance documents

Microsoft provides detailed guidance that is relevant to EPCS multi-factor authentication:

- How to configure Azure AD to meet NIST SP 800-63B Authenticator Assurance Levels, including AAL1, AAL2, and AAL3. For more information, see Achieving NIST AALs.

- How to configure controls in the Access Control (AC) and Identification and Authentication (IA) control families to meet FedRAMP High requirements. For more information, see Configure Azure AD to meet FedRAMP High.

# Frequently asked questions

**Can Azure support my EPCS multi-factor authentication requirements?**
Yes. Azure can help you meet your EPCS multi-factor authentication requirements because Azure AD supports both authenticator and verifier NIST SP 800-63B Authenticator Assurance Level 3 (AAL3) requirements, including FIPS 140 validation at the requisite level. Azure AD exceeds the EPCS multi-factor authentication requirements. We recommend using a multi-factor cryptographic hardware authenticator to achieve AAL3. FIDO2 security keys, smartcards, and Windows Hello for Business can help you meet AAL3 requirements, which in turn cover EPCS multi-factor authentication requirements. For more information, see Azure NIST SP 800-63 documentation. You can also use the **Microsoft Authenticator app**, which meets FIPS 140 Level 1 validation requirements for all Azure AD authentications, as explained in Authentication methods in Azure Active Directory - Microsoft Authenticator app.

**Does Microsoft provide guidance on achieving NIST SP 800-63B AAL3 requirements?**
Yes. For more information, see Guidance documents.

# Resources

- Azure compliance documentation
- Azure enables a world of compliance
- Microsoft 365 compliance offerings
- Compliance on the Microsoft Trust Center
- What is Azure Government?
- Explore Azure Government
- Microsoft government solutions
- Electronic Prescriptions for Controlled Substances (EPCS)
- NIST SP 800-63 *Digital Identity Guidelines*
- NIST SP 800-63A *Enrollment and Identity Proofing*
- NIST SP 800-63B *Authentication and Lifecycle Management*
- NIST SP 800-63C *Federation and Assertions*

---

Last updated on 12/06/2022